

Résumé de la faille

Un service réseau (nc) présente successivement trois hash à casser (MD5, puis SHA1, puis SHA256), chacun correspondant à un mot de passe faible présent dans la wordlist **rockyou.txt**. Il faut casser les trois dans l'ordre, dans la **même session nc** , pour obtenir le flag.

Concept : cracking de hash par dictionnaire (wordlist attack) — la faiblesse n'est pas dans l'algorithme de hash lui-même, mais dans le choix de mots de passe trop communs/faibles.

Méthodo — les étapes

1. Se connecter au service et récupérer le premier hash

```
nc verbal-sleep.picoctf.net 52455
```

→ 482c811da5d5b4bc6d497ffa98491e38 (32 caractères hexadécimaux → MD5)

2. Identifier l'algorithme par la longueur du hash

Longueur (hex)	Algorithme probable
32 caractères	MD5
40 caractères	SHA1
64 caractères	SHA256

3. Préparer rockyou.txt (déjà présent sur Kali)

```
ls -la /usr/share/wordlists/rockyou*
gunzip /usr/share/wordlists/rockyou.txt.gz # si encore compressé
```

4. Cracker chaque hash avec John the Ripper

```
echo "HASH ICI" > hash.txt
john --wordlist=/usr/share/wordlists/rockyou.txt --format=FORMAT hash.txt
```

- format=raw-md5 pour un hash MD5 (32 car.)
- format=raw-SHA1 pour un hash SHA1 (40 car.)
- format=raw-SHA256 pour un hash SHA256 (64 car.)

Résultats obtenus : - MD5 → password123 - SHA1 → letmein - SHA256 → qwerty098

5. Répondre dans la MÊME session nc, dans l'ordre

```
Enter the password for identified hash: password123
Correct! ... Crack this hash: b7a875fc...
Enter the password for the identified hash: letmein
Correct! ... Crack this hash: 916e8c4f...
Enter the password for the identified hash: qwerty098
Correct! The flag is: picoCTF{...}
```

⚠ Chaque connexion nc redémarre la séquence depuis le début — il faut enchaîner les 3 bonnes réponses d'affilée dans une seule session, pas les tester séparément sur des connexions différentes.

❗ Piège rencontré : le cache de John ("No password hashes left to crack")

En relançant john sur un nouveau hash mis dans le même fichier hash.txt , l'erreur "No password hashes left to crack" est apparue — alors que le mot de passe n'avait pourtant pas encore été trouvé pour ce hash précis.

Cause : John garde un cache persistant (~/.john/john.pot) de tous les hashes déjà traités lors de sessions précédentes. Si le même hash (ou un hash qu'il a déjà "vu") repasse, il peut considérer qu'il n'y a rien de nouveau à faire.

Diagnostic : vérifier si John a DÉJÀ trouvé le mot de passe :

```
john --show --format=FORMAT hash.txt
```

S'il affiche un résultat (?:motdepasse) → le hash a déjà été cassé lors d'un essai précédent, pas besoin de relancer.

Si vraiment aucun résultat en cache, forcer un nouveau run avec un cache vierge :

```
john --wordlist=... --format=... --pot=nouveau.pot hash.txt
```

ou vider le cache global (rm ~/.john/john.pot) pour repartir de zéro.

Outils utilisés

Outil	Rôle
<code>nc</code> (netcat)	Se connecter au service du challenge, dialoguer en direct
<code>john</code> (John the Ripper)	Cracker les hash par dictionnaire (wordlist attack)
<code>rockyou.txt</code>	Wordlist de mots de passe réels ayant fuité (14M+ entrées)

Réflexes à retenir

- **Longueur du hash en hexadécimal** = indice fort sur l'algorithm (32→MD5, 40→SHA1, 64→SHA256).
- rockyou.txt est **déjà présent** sur Kali (`/usr/share/wordlists/`), pas besoin de le télécharger — juste le décompresser si besoin.
- `john --show --format=X fichier` permet de vérifier si un hash a déjà été cassé (utile pour diagnostiquer un "No hashes left to crack").
- Dans un challenge en **chaîne via un service réseau (nc)**, bien répondre dans la même session, dans l'ordre — chaque connexion redémarre la séquence depuis le début.
- Le cracking par dictionnaire ne marche que si le mot de passe est dans la wordlist utilisée — sinon il faut une wordlist différente ou une autre approche (bruteforce, règles de mutation...).

Dans la vraie vie

Ce challenge illustre une réalité très concrète de la sécurité : même un hash cryptographiquement solide (SHA256) ne protège rien si le mot de passe hashé est trop faible/commun. Le nom du flag résume ça : "Use Strong Hashes & Passwords" — la force du hash ET du mot de passe comptent, l'un sans l'autre ne suffit pas.

En audit de sécurité réel, cracker des hash de mots de passe fuités (dumps de bases de données) avec rockyou.txt (ou des wordlists plus grandes) est une pratique courante pour évaluer la robustesse réelle des mots de passe utilisés dans une organisation.